CSE703093 – An toàn phần mềm

Software Security

ThS. Vũ Quang Dũng TS. Trịnh Thanh Bình TS. Đoàn Trung Sơn

Khoa Hệ thống thông tin – Trường Đại học Phenikaa

Học kỳ hiện tại

Nội dung

1. Giới thiệu học phần
2. Chuẩn đầu ra học phần
3. Đánh giá học phần

Thông tin chung

- **Mã học phần:** CSE703093
- **Số tín chỉ:** 3 (Lý thuyết: 2, Thực hành: 1, Tự học: 6)
- **Loại học phần:** Lý thuyết kết hợp thực hành
- **Giảng viên phụ trách:** ThS. Vũ Quang Dũng
- **Giảng viên tham gia:** TS. Đoàn Trung Sơn, TS. Trịnh Thanh Bình

Mô tả tóm tắt học phần

Trang bị cho sinh viên các kiến thức cơ bản về an toàn phần mềm:

- Lỗ hổng bảo mật (vulnerabilities), tấn công mạng, và các nguy cơ liên quan đến sự không an toàn của phần mềm
- Các phương pháp, kỹ thuật và công cụ để **phòng ngừa** và **phát hiện** lỗi phần mềm
- Trọng tâm: mô hình hóa, kiểm chứng (verification), kiểm thử (testing), đánh giá mã nguồn (code review / static analysis)

Tài liệu học tập

Giáo trình chính:

[1] Graham, van Veenendaal, Evans, Black (2020), *Foundations of Software Testing – ISTQB Certification*, Cengage Learning.

Tài liệu tham khảo:

[2] Malini Rao (2023), *AI and ML in Cybersecurity*, Success Publications.

Chuẩn đầu ra học phần (Learning Outcomes)

LO	Mô tả
LO.1	Diễn giải được các vấn đề bảo mật hệ thống và xác định tại sao phần mềm lỗi là nguyên nhân chính
LO.03	Đánh giá các kỹ thuật thẩm định và kiểm chứng phần mềm để kiểm tra các lỗ hổng bảo mật
LO.04	Thực hiện thành thạo giải quyết các lỗ hổng bảo mật bằng các kỹ thuật kiểm chứng và kiểm thử phần mềm

Cấu trúc học phần theo tuần

Buổi	Nội dung	CĐR
3	Chương 1: Giới thiệu về an toàn phần mềm	LO.1
4	Ôn tập	LO.04
5	Chương 2: Lập trình C an toàn – Quản lý bộ nhớ	LO.1
6	Chương 3: Phát hiện lỗ hổng phần mềm – Phân tích tĩnh	LO.03, LO.04
7	Chương 4: Phát hiện lỗ hổng phần mềm – Phân tích động	LO.04
2	Kiểm tra giữa kỳ (trắc nghiệm)	LO.1
1	Báo cáo bài tập lớn	LO.1, LO.03, LO.04

Cấu trúc điểm

- **Chuyên cần (10%)**
  - CC1. Điểm danh – 5%
  - CC2. Đánh giá tích cực (phát biểu, thảo luận) – 5%
- **Đánh giá giữa kỳ (40%)**
  - B2. Thi trắc nghiệm trên máy tính – theo LO.1, LO.03, LO.04
- **Đánh giá cuối kỳ (50%)**
  - KTHP. Bài tập lớn (không thuyết trình) – theo LO.03, LO.04

Yêu cầu và quy định

- Dự lớp tối thiểu **80%** thời lượng học phần
- Học trên phòng máy – cần máy tính để thực hành
- Mỗi buổi học kết hợp: thuyết giảng $\rightarrow$ thao tác thực hành mẫu $\rightarrow$ bài tập thực hành trên lớp $\rightarrow$ bài tập về nhà

Lộ trình nội dung

Chương 1. Giới thiệu an toàn phần mềm: khái niệm bảo mật, cấu trúc Kripke, kiểm thử & kiểm chứng

↓

Chương 2. Lập trình C an toàn: quản lý bộ nhớ, cấu trúc dữ liệu động, static analysis

↓

Chương 3. Phát hiện lỗ hổng: phân tích tĩnh, SAT/SMT, bounded model checking

↓

Chương 4. Phát hiện lỗ hổng: phân tích động, code coverage, fuzzing (black-box/white-box)

↓

Chương 5 trở đi. An toàn phần mềm nâng cao và ứng dụng trong công nghệ hiện đại (black-box/white-box)

Dự án Python xuyên suốt môn học

Trong suốt học phần, sinh viên xây dựng một bộ công cụ Python `softsec-toolkit` gồm các module tương ứng từng chương:

- **ch1_models**: mô hình hóa Kripke structure, mô phỏng automata trạng thái bảo mật
- **ch2_memsafe**: công cụ phát hiện lỗi bộ nhớ cơ bản trên mã C (mô phỏng buffer overflow, phân tích tĩnh đơn giản)
- **ch3_staticsat**: bộ giải SAT/SMT đơn giản, bounded model checker mini
- **ch4_dynafuzz**: công cụ đo code coverage và fuzzer (black-box, white-box) cho chương trình Python mẫu

Đây cũng chính là nền tảng cho **bài tập lớn cuối kỳ**.

Câu hỏi?

Chúc các bạn học tốt!